

Cloud risk in dollars

How Onam prices a verified attack path with FAIR — using named, external inputs a board can defend.

FAIR / ALE

IBM 2024 costs

Sensitivity ×

Regulatory ×

Exposure roll-up

EXECUTIVE SUMMARY

Severity tells you what is broken. Dollars tell you what to fix first.

Security teams are drowning in "criticals." Boards are not asking how many — they are asking how much. This paper explains how Onam turns a verified attack path into a defensible financial figure using FAIR, the open standard for risk quantification, so the conversation moves from a spreadsheet of severities to a single number a board can act on.

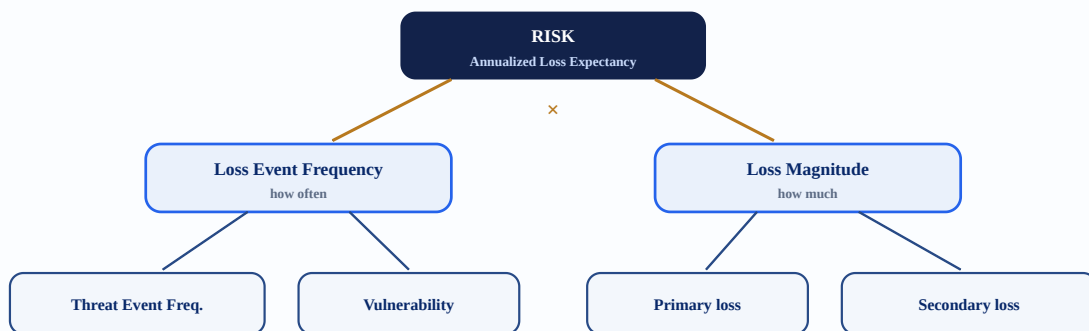
FAIR — Factor Analysis of Information Risk — is a published, peer-reviewed methodology maintained as an open standard. It decomposes risk into estimable factors and produces an Annualized Loss Expectancy (ALE) in currency. Onam implements FAIR as the fourth layer of its pipeline: after a path is found, verified, and mapped to MITRE ATT&CK, it is priced. The pricing is not a marketing gauge invented in-house; it is a recognized model fed with named, external inputs.

Why this is the wedge. A security graph and attack paths are now common across the CNAPP market. A defensible dollar figure — derived from a published model and named external cost data, attached to a specific verified path — is not. It is the difference between "we have 200 criticals" and "this one over-privileged role carries the largest single slice of our quantified exposure."

01 The FAIR model, briefly

FAIR expresses risk as the product of how often a loss happens and how big it is when it does:

FIGURE 1 — FAIR DECOMPOSITION



Onam computes each leaf factor from graph-derived evidence rather than a workshop guess: frequency and vulnerability from reachability and control state; magnitude from data sensitivity and record counts.

The strength of FAIR is that each factor is *estimable and inspectable*. When Onam prices a path, a reviewer can open the calculation and see which input drove the number — not a black-box score between 0 and 100.

02 The inputs — named, external, defensible

A dollar figure is only as credible as the numbers behind it. Onam deliberately sources its magnitude inputs from a recognized external benchmark and applies transparent multipliers.

Input	Source / basis	Effect
Per-record breach cost	IBM <i>Cost of a Data Breach 2024</i> — by industry	Healthcare ≈ \$10.93/record ... default ≈ \$4.45/record
Data-sensitivity multiplier	Onam data classification (DSPM)	Restricted ×3.0 → Confidential → Internal → Public ×0.1
Regulatory multiplier	Applicable regime (GDPR, etc.)	Highest applicable applied (e.g. GDPR ×1.5)
Blast radius	The property graph	Weights exposure by how much the path can actually reach
Severity	Finding evaluation	Weights likelihood contribution

Defensible by construction. Every magnitude figure traces to IBM's published per-record cost multiplied by a sensitivity factor and, where relevant, a regulatory factor. An auditor or a skeptical board member can follow the arithmetic. That traceability is the point.

03 From a path to a price

- 1 Locate the loss.** A verified path ends at a crown jewel — a data store or admin identity. Onam reads the store's classification and record count (labels and locations only; contents are never retained).
- 2 Estimate frequency.** Loss Event Frequency is shaped by how reachable the entry is and how many controls the path defeats — evidence the graph already holds.
- 3 Estimate magnitude.** Record count × IBM per-record cost × sensitivity × regulatory multiplier yields Loss Magnitude.
- 4 Roll up.** Exposure aggregates per finding, per asset, and per account — so the same model answers "what is this path worth" and "what is this account's total exposure."

04 Why a dollar beats a score

Competing platforms prioritize with proprietary scales — toxic-combination flags, 0–99 business-impact scores, Critical-to-Low risk levels. Each is useful internally, but none is a currency figure a board recognizes, and none is portable across a risk register that already speaks in dollars.

FIGURE 2 — THE SAME EXPOSURE, TWO LANGUAGES

SCORE (proprietary)

Business impact: 87 / 100

Board question it cannot answer: "so how much?"

DOLLARS (FAIR)

Annualized exposure on this path: \$X.XM

Slots directly into the enterprise risk register.

Figures shown in demos are illustrative, not benchmarks.

A score ranks within one tool. A FAIR dollar figure travels — into the risk register, the board pack, and the cyber-insurance conversation.

05 Prioritization changes when risk is priced

Once every path carries a dollar figure, the work queue re-sorts itself around **exposure reduced per fix**. A choke point that sits on many priced paths rises to the top even if its own finding severity is modest; an isolated "critical" with no path to anything valuable falls. This is the practical payoff: teams spend their limited remediation budget where it removes the most quantified risk, and they can prove it afterward — exposure before, exposure after.

The board sentence. "We reduced quantified cloud exposure by \$N this quarter by fixing five choke points" is a sentence FAIR makes possible and a severity list does not.

06 Honesty about a quantified number

A model, not a prophecy. FAIR produces a defensible estimate, not a guaranteed outcome. Its value is in relative prioritization and in giving the board a currency-denominated view — not in predicting the exact cost of a future breach. Onam labels demo dollar figures as illustrative and never presents them as customer benchmarks. The inputs are named so the estimate can be challenged and refined, which is exactly how a credible risk figure should behave.

Two disciplines keep the number trustworthy. First, inputs are external and cited (IBM 2024), so the magnitude side is anchored to published data rather than internal assertion. Second, the frequency side is driven by graph-derived evidence of reachability and control state, so it moves when the environment actually changes — a path that gets harder to walk gets cheaper, automatically, on the next scan.

07 Summary

Onam prices verified attack paths with FAIR, an open and inspectable model, using named external inputs — IBM's 2024 per-record breach costs, data-sensitivity multipliers, and regulatory factors — weighted by the blast radius the graph already computed. The result is an annualized exposure figure per finding, asset, and account that a board recognizes and a risk register can hold. Where competitors stop at a proprietary score, Onam produces a currency figure you can defend, challenge, and track down over time.

See your number. A read-only connect prices your own environment the way this paper describes — every figure traceable to a named input, computed on the same graph that found the path.